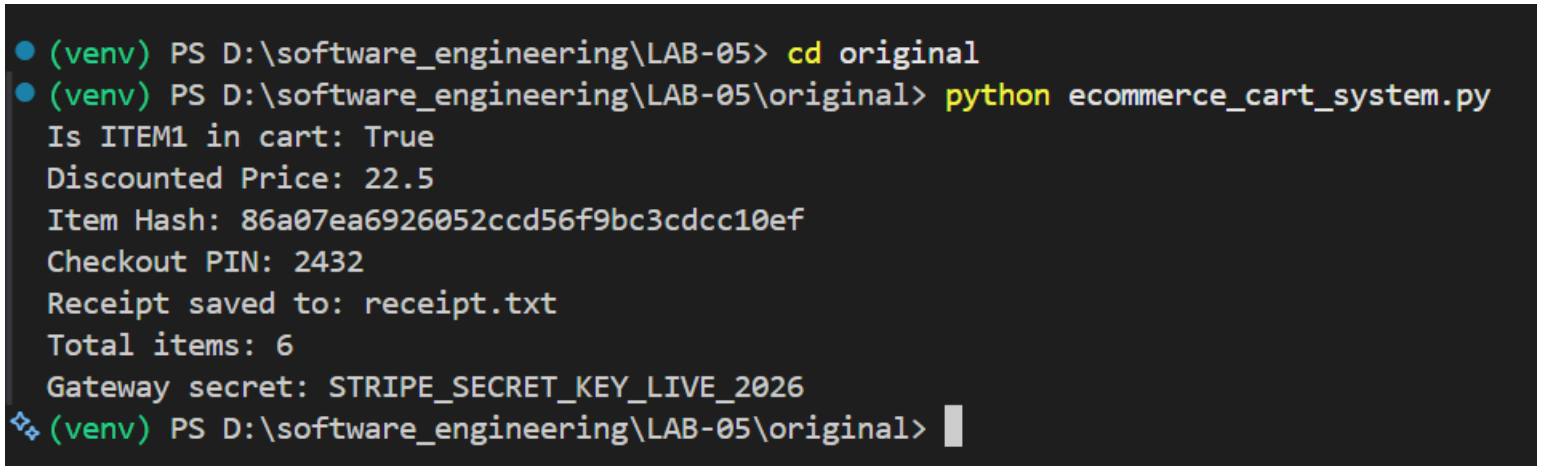
Lab 5: Static Code Analysis — E-Commerce Cart System

Git-Hub repo link: https://github.com/CipherVerse-600271/Lab5-Static-Code-Analysis.git

Name	Bharath K
SRN	PES2UG24CS113

Tool_output_screenshots

Original code execution



Initial analysis: Pylint report

```
(venv) PS D:\software_engineering\LAB-05\original> pylint ecommerce_cart_system.py
************* Module ecommerce_cart_system
ecommerce_cart_system.py:84:0: C0304: Final newline missing (missing-final-newline)
ecommerce_cart_system.py:1:0: C0114: Missing module docstring (missing-module-docstring)
ecommerce_cart_system.py:12:0: C0103: Constant name "total_sales" doesn't conform to UPPER_CASE naming style (invalid-name)
ecommerce_cart_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:15:0: C0103: Function name "addItemToCart" doesn't conform to snake_case naming style (invalid-name)
ecommerce_cart_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
ecommerce_cart_system.py:16:4: W0603: Using the global statement (global-statement)
ecommerce_cart_system.py:21:21: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
ecommerce_cart_system.py:25:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:25:0: C0103: Function name "removeItemFromCart" doesn't conform to snake_case naming style (invalid-name)
ecommerce_cart_system.py:28:4: W0702: No exception type(s) specified (bare-except)
ecommerce_cart_system.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:32:0: C0103: Function name "checkCartStatus" doesn't conform to snake_case naming style (invalid-name)
ecommerce_cart_system.py:34:7: C0121: Comparison 'cart_items.get(item_id) == None' should be 'cart_items.get(item_id) is None' (singleton-comparison)
ecommerce_cart_system.py:36:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
ecommerce_cart_system.py:36:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
ecommerce_cart_system.py:33:4: W0612: Unused variable 'handling_fee' (unused-variable)
ecommerce_cart_system.py:42:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:42:0: C0103: Function name "calculateDiscountedTotal" doesn't conform to snake_case naming style (invalid-name)
ecommerce_cart_system.py:44:19: W0123: Use of eval (eval-used)
ecommerce_cart_system.py:43:4: W0612: Unused variable 'base_price' (unused-variable)
ecommerce_cart_system.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:48:0: C0103: Function name "generateItemHash" doesn't conform to snake_case naming style (invalid-name)
ecommerce_cart_system.py:52:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:52:0: C0103: Function name "generateCheckoutPin" doesn't conform to snake_case naming style (invalid-name)
ecommerce_cart_system.py:56:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:56:0: C0103: Function name "exportCartReceipt" doesn't conform to snake_case naming style (invalid-name)
ecommerce_cart_system.py:57:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
ecommerce_cart_system.py:57:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
ecommerce_cart_system.py:63:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:63:0: C0103: Function name "getCartSummary" doesn't conform to snake_case naming style (invalid-name)
ecommerce_cart_system.py:63:19: W0621: Redefining name 'cart_items' from outer scope (line 6) (redefined-outer-name)
ecommerce_cart_system.py:65:8: W0612: Unused variable 'k' (unused-variable)
ecommerce_cart_system.py:71:0: C0116: Missing function or method docstring (missing-function-docstring)
ecommerce_cart_system.py:4:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 3.86/10
```

Initial analysis: Bandit report

```
(venv) PS D:\software_engineering\LAB-05\original> bandit -r ecommerce_cart_system.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.0
Run started:2026-10-14 17:14:28.236335+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\ecommerce_cart_system.py:28:4
27              del cart_items[item_id]
28          except:
29              pass
30

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\ecommerce_cart_system.py:44:19
43          base_price = cart_items[item_id]["price"]
44          final_amount = eval(discount_expr)
45          return final_amount

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\ecommerce_cart_system.py:49:11
48      def generateItemHash(item_id):
49          return hashlib.md5(item_id.encode()).hexdigest()
50

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\ecommerce_cart_system.py:53:11
52      def generateCheckoutPin():
53          return random.randint(1000, 9999)
54

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\ecommerce_cart_system.py:60:4
59          f.close()
60          os.system("echo Receipt saved to: " + filename)
61
```

```
--------------------------------------------------

Code scanned:
        Total lines of code: 62
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 5
Files skipped (0):
```

Initial analysis: Flake8 report

```
(venv) PS D:\software_engineering\LAB-05\original> flake8 ecommerce_cart_system.py
ecommerce_cart_system.py:4:1: F401 'math' imported but unused
ecommerce_cart_system.py:28:5: E722 do not use bare 'except'
ecommerce_cart_system.py:33:5: F841 local variable 'handling_fee' is assigned to but never used
ecommerce_cart_system.py:34:32: E711 comparison to None should be 'if cond is None:'
ecommerce_cart_system.py:43:5: F841 local variable 'base_price' is assigned to but never used
ecommerce_cart_system.py:76:80: E501 line too long (86 > 79 characters)
ecommerce_cart_system.py:84:7: W292 no newline at end of file
```

```
(venv) PS D:\software_engineering\LAB-05\original> pylint ecommerce_cart_system.py > pylint_report.txt
>> bandit -r ecommerce_cart_system.py > bandit_report.txt
>> flake8 ecommerce_cart_system.py > flake8_report.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.0
(venv) PS D:\software_engineering\LAB-05\original> dir


    Directory: D:\software_engineering\LAB-05\original


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----        14-10-2026     22:44           5720 bandit_report.txt
-a----        14-10-2026     22:36           2185 ecommerce_cart_system.py
-a----        14-10-2026     22:44           1080 flake8_report.txt
-a----        14-10-2026     22:44           8058 pylint_report.txt
-a----        14-10-2026     22:42            180 receipt.txt


(venv) PS D:\software_engineering\LAB-05\original>
```

Corrected code:

```
(venv) PS D:\software_engineering\LAB-05> python ecommerce_cart_system.py
Is ITEM1 in cart: True
Discounted Price: 22.5
Item Hash: de124cf18e4be214c25c0c75410474d1b4c4b45679baa47caf3404bd34c806dc
Checkout PIN: 4574
Receipt saved to: receipt.txt
Total items: 6
Cart value: 220.0
Audit log: ['Added ITEM4 with price 35.00']
Gateway key configured: False
```

Final analysis results

```
(venv) PS D:\software_engineering\LAB-05> pylint ecommerce_cart_system.py
>> bandit -r ecommerce_cart_system.py
>> flake8 ecommerce_cart_system.py

-------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 3.86/10, +6.14)

[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.0
Run started:2026-10-14 17:20:37.533820+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 64
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
(venv) PS D:\software_engineering\LAB-05>
```